YY-MM-ABCD

EGS Security Solutions

Initial Client Worksheet

EGS Security Services
Penetration Testing Teleconference Worksheet

Section 1 - Client Information

Client On-Site Address	Primary Contact	Alternate Contact
Company:	Name:	Name:
Street Address:	Phone:	Phone:
City, State, ZIP:	Email:	Email:

Section 2 – Teleconference Information

Date & Time:	Point of Contact:	Teleconference Number:

Section 3 – Client Requirements

Facilitated Risk Analysis Process (FRAP)

Component	Y	N	Component	Y	N
Initial FRAP	☐	☐	Follow-up on Risk Action Plan	☐	☐
Detailed analysis of Risk Action Plan	☐	☐			

Information Systems Security Assessment

Component	Y	N	Component	Y	N
Antivirus Administration & Configuration	☐	☐	Network Topology	☐	☐
Business Continuity Plan (BCP) & Disaster Recovery Plan (DRP)	☐	☐	Patch Management Process	☐	☐
Core Application System Security What core system is in use?	☐	☐	Physical Security	☐	☐

Data Backup & Recovery	☐	☐	Policy, Procedures and Documentation	☐	☐
Firewall Administration & Configuration	☐	☐	Router Administration & Configuration	☐	☐
Follow-up Status of Recommendations	☐	☐	Server Administration & Configuration	☐	☐
Insurance Coverage	☐	☐	Switch Administration & Configuration	☐	☐
Network Monitoring & Intrusion Detection	☐	☐	Workstation Administration & Configuration	☐	☐

FOOTPRINTING IFORMATION ANALYSIS	☐ **Y**	☐ **N**

EXTERNAL VULNERABILITY ASSESSMENT			
Component		**Y**	**N**
Internet Vulnerability Assessment (Once)		☐	☐
Number External IPs to be tested:		Total number external IPs in organization:	

INTERNAL VULNERABILITY ASSESSMENT			
Component		**Y**	**N**
Network Vulnerability Assessment (Once)		☐	☐
Number Internal IPs to be tested:		Total number internal IPs in organization:	

EXTERNAL PENETRATION TESTING

Testing type: ☐ **Black Box** ☐ **White Box** ☐ **Gray Box**

Component	**Y**	**N**	**Component**	**Y**	**N**
Firewalls	☐	☐	IDS	☐	☐
Passwords	☐	☐	SQL Injection	☐	☐
Web servers	☐	☐	Routers	☐	☐
Web Applications	☐	☐	Email server	☐	☐
Other:	☐	☐	Other:	☐	☐
Other:	☐	☐	Other:	☐	☐
Other:	☐	☐	Other:	☐	☐
Other:	☐	☐	Other:	☐	☐

INTERNAL PENETRATION TESTING					
Testing type: ☐ **Black Box** ☐ **White Box** ☐ **Gray Box**					
Component	**Y**	**N**	**Component**	**Y**	**N**
Operating systems	☐	☐	Applications	☐	☐
Routers	☐	☐	Switches	☐	☐
Other:	☐	☐	Other:	☐	☐
Other:	☐	☐	Other:	☐	☐
Other:	☐	☐	Other:	☐	☐

EXTERNAL MODEM/FAX SERVER VULNERABILITY ASSESSMENT (WAR DIALING)	☐ Y	☐ N

SOCIAL ENGINEERING SECURITY ASSESSMENT					
Component	**Y**	**N**	**Component**	**Y**	**N**
Human-based	☐	☐	Computer-based	☐	☐
Dumpster Diving	☐	☐	Shoulder Surfing	☐	☐
Other:	☐	☐	Other:	☐	☐
Other:	☐	☐	Other:	☐	☐

WIRELESS NETWORK (WLAN) SECURITY ASSESSMENT	☐ Y	☐ N
PHYSICAL SECURITY ASSESSMENT	☐ Y	☐ N
CLOUD SECURITY ASSESSMENT	☐ Y	☐ N
MOBILE DEVICE SECURITY ASSESSMENT	☐ Y	☐ N
GRAMM-LEACH-BLILEY GAP ANALYSIS	☐ Y	☐ N
PCI-DSS GAP ANALYSIS	☐ Y	☐ N
HIPPA GAP ANALYSIS	☐ Y	☐ N
FISMA GAP ANALYSIS	☐ Y	☐ N
SOX GAP ANALYSIS	☐ Y	☐ N
OTHER :	☐ Y	☐ N
OTHER :	☐ Y	☐ N
OTHER :	☐ Y	☐ N

YY-MM-ABCD

SECTION 4– TELECONFERENCE NOTES

EGS SECURITY SERVICES PENETRATION TESTING TELECONFERENCE WORKSHEET	FREQUENTLY ASKED QUESTIONS

FRAP - Facilitated **R**isk **A**ssessment **P**rocess

Initial FRAP - Sessions with key personnel from EACH department. Participants identify critical information assets, assess threats and vulnerabilities to identified assets, analyze the impact on the organization of identified threats and identify mitigating controls. Risks are identified and prioritized using the CIA Triad of Confidentiality, Integrity and Availability. Mitigating controls are then assigned to each risk. Deliverables include a Risk Action Plan template that the client organization will use to assign timelines and responsible persons to each identified risk and associated controls.

Follow Up of Risk Action Plan – review of existing RAP in light of changes in the client organization's security environment

Detailed analysis of Risk Action Plan – Review of existing RAP, breaking general risks into specific areas, e.g., power outage becomes power outage > 30 min, power outage > 1 day, power outage > 1 week)

ISSA: ANTIVIRUS ADMINISTRATION & CONFIGURATION

Includes review of existing policies and procedures with recommendations for minimum included items; review of installed AV software (version, patch & hotfix level, capabilities, update frequency, distribution scheme); host/appliance OS security, patch & hotfix level; AV client configuration and AV training for administrators and end users. Includes recommendations for industry "best practices".

ISSA: BCP/DRP

Documentation, content and sufficiency of policies and procedures relating to the core application system; includes logical controls, physical access controls, reports and error reporting, change management, third party remote access control and recommendations for industry "best practices."

ISSA: CORE APPLICATION SYSTEMS SECURITY

Includes review of existing policies and procedures related to the control of the client organization's core system host and application. Includes recommendations for industry "best practices".

ISSA: DATA BACKUP & RECOVERY

Includes review of existing policies and procedures with recommendations for minimum included items; review of installed backup software (version, patch & hotfix level, capabilities); host/appliance OS security, patch & hotfix level; backup software change control processes; types and frequency of data backups; media labeling, accountability, inventory and reconciliation procedures; on and off-site storage of media and data recovery testing procedures. Includes recommendations for industry "best practices".

ISSA: FIREWALL ADMINISTRATION & CONFIGURATION

If a Perimeter and Core Infrastructure Assessment is not part of the engagement, FAC includes review of existing policies and procedures related to the administration of the credit union's firewall(s); examination of firewall configuration files and access control lists. Includes recommendations for industry "best practices". If a Perimeter and Core Infrastructure Assessment is part of the engagement, these items as well as additional items are reported in the appropriate section of the PCIA.

ISSA: FOLLOW-UP STATUS OF RECOMMENDATIONS FROM PREVIOUS IS REVIEWS BY THE CLIENT ORGANIZATION'S REGULATORS & EXTERNAL AUDITORS

Includes examination of previous Information Systems reviews conducted by the client organization's regulators and external auditors; examination of follow up actions on the findings of those reviews.

ISSA: Insurance Coverage
Includes review of existing insurance policies and coverage levels; recommendations of coverage levels based on current the client organization's environment.
ISSA: Network Monitoring & Intrusion Detection
If a Perimeter and Core Infrastructure Assessment is not part of the engagement, NMP includes review of existing policies and procedures related to intrusion detection and review of the configuration files of intrusion detection systems and host devices. Includes recommendations for industry "best practices." If a Perimeter and Core Infrastructure Assessment is part of the engagement, these items as well as additional items are reported in the appropriate section of the PCIA.
ISSA: Network Topology
Includes review of existing policies and procedures related to network topology configuration and documentation; verification that network documentation is current and reflects the actual network topology.
ISSA: Patch Management Process
Includes review of existing policies and procedures with recommendations for minimum included items; review of installed PM software (version, patch & hotfix level, capabilities, update frequency, distribution scheme); host/appliance OS security, patch & hotfix level; PM change control and back out procedures.
ISSA: Physical Security
If Social Engineering as not part of the engagement, PS includes review of existing policies and procedures related to the physical security of the client organization and its assets, walk through during both business and non-business hours and sanitation reconnaissance. Includes recommendations for industry "best practices." If Social Engineering is part of the engagement, these items as well as additional items are reported in the appropriate section of the SEA.
ISSA: Policy, Procedure and Documentation – Review and Evaluation
Includes review of existing policies and procedures related to Information Security.
ISSA: Router Administration & Configuration
If a Perimeter and Core Infrastructure Assessment is not part of the engagement, RAC includes review of existing policies and procedures related to the administration of the client organization's router(s); examination of router configuration files and access control lists. Includes recommendations for industry "best practices." If a Perimeter and Core Infrastructure Assessment is part of the engagement, these items as well as additional items are reported in the appropriate section of the PCIA.
ISSA: Server Administration & Configuration
If a Perimeter and Core Infrastructure Assessment is not part of the engagement, SAC includes review of existing policies and procedures related to the administration of the client organization's server(s); examination of server configuration files and access control lists. Includes recommendations for industry "best practices." If a Perimeter and Core Infrastructure Assessment is part of the engagement, these items as well as additional items are reported in the appropriate section of the PCIA.
ISSA: Switch Administration & Configuration

If a Perimeter and Core Infrastructure Assessment is not part of the engagement, SWAC includes review of existing policies and procedures related to the administration of the client organization's switch(es); examination of switch configuration files and access control lists. Includes recommendations for industry "best practices." If a Perimeter and Core Infrastructure Assessment is part of the engagement, these items as well as additional items are reported in the appropriate section of the PCIA.
ISSA: WORKSTATION ADMINISTRATION & CONFIGURATION
If a Perimeter and Core Infrastructure Assessment is not part of the engagement, DAC includes review of existing policies and procedures related to the administration of the client organization's desktop computers and review of the security configuration of desktop operating systems and host devices. Includes recommendations for industry "best practices." If a Perimeter and Core Infrastructure Assessment is part of the engagement, these items as well as additional items are reported in the appropriate section of the PCIA.
INTERNET FOOT PRINT INFORMATION ANALYSIS
Uses the Internet to search for information that could assist an attacker in gaining access to the client organization's network. Includes examination of the client organization's web site HTML code (as seen by an attacker) and search results for contact names, email addresses, product endorsements, personal information, etc. that could be used by an attacker.
EXTERNAL VULNERABILITY ASSESSMENT
Examines an organization's security profile from the perspective of an outsider or someone who does not have access to systems and networks behind the organization's external security perimeter.
NETWORK VULNERABILITY ASSESSMENT
Scan, investigate, analyze, and report on the level of risk associated with any security vulnerabilities discovered on the public, internet-facing devices and to provide your organization with appropriate mitigation strategies to address those discovered vulnerabilities.
EXTERNAL PENETRATION TESTING
Attempts to breach the target as an unauthorized user with varying levels of access. An External Penetration Test mimics the actions of an actual attacker exploiting weaknesses in the network security without the usual dangers. This test examines external IT systems for any weakness that could be used by an external attacker to disrupt the confidentiality, availability or integrity of the network, thereby allowing the organisation to address each weakness.
INTERNAL PENETRATION TESTING
Mimics the actions of an actual attacker exploiting weaknesses in network security. This test examines internal IT systems for any weakness that could be used to disrupt the confidentiality, availability, or integrity of the network, thereby allowing the organization to address each weakness.
SOCIAL ENGINEERING SECURITY ASSESSMENT
Consists of impersonating a trusted individual in an attempt to gain information and/or access to information or the client network infrastructure.
GRAMM-LEACH-BLILEY GAP ANALYSIS
Performed in conjunction with the Internal Vulnerability Assessments and Analysis order to evaluate our client's compliance in respect to "safeguarding member information" per the Gramm-Leach-Bliley Act.